TRƯỜNG ĐẠI HỌC BÁCH KHOA TP. HỒ CHÍ MINH
KHOA KHOA HỌC VÀ KỸ THUẬT MÁY TÍNH



INTERIM REPORT
MÔN: CÔNG NGHỆ PHẦN MỀM THẾ HỆ MỚI (CO5151)

SECURE AGENTIC BI FRAMEWORK

GVHD: TS. Lê Xuân Bách
HVTH: Nguyễn Hữu Lợi - 2470012
Nguyễn Công Thành - 2470744
Phạm Quỳnh Trân - 2470731

TP. Hồ Chí Minh, 10/2026

Mục lục

TÓM TẮT DỰ ÁN **3**

1 Kiến trúc hệ thống và cơ chế bảo mật **4**

1.1 Cơ sở thiết kế 4

1.2 Phân quyền, kiểm định truy vấn và thực thi 4

1.3 Vòng lặp Agent, MCP và cơ chế phục hồi 5

2 Phương pháp đánh giá và kết quả thực nghiệm **6**

2.1 Tập kiểm thử và chỉ số đánh giá 6

2.2 Phân tích kết quả và giới hạn 7

3 Mô hình đe dọa, phạm vi và hướng phát triển **8**

3.1 Mô hình đe dọa 8

3.2 Thành phần đã triển khai và phần mở rộng dự kiến 9

4 Kế hoạch đến báo cáo cuối kỳ và tự đánh giá tiến độ **10**

4.1 Lộ trình triển khai 10

4.2 Rủi ro và phương án dự phòng 10

4.3 Tự đánh giá tiến độ 10

5 Đóng góp thành viên và tuyên bố sử dụng AI **11**

5.1 Đóng góp của các thành viên 11

5.2 Tuyên bố sử dụng trí tuệ nhân tạo 11

Tài liệu tham khảo **12**

TÓM TẮT DỰ ÁN

Xu hướng tích hợp Mô hình Ngôn ngữ Lớn (LLM) vào các hệ thống Trí tuệ Doanh nghiệp (Business Intelligence - BI) đang tạo ra một bước chuyển dịch đột phá từ truy vấn SQL thủ công sang giao diện đàm thoại ngôn ngữ tự nhiên (*Natural Language to SQL - NL2SQL*). Tuy nhiên, việc cho phép LLM Agent tự động kết nối và thực thi trực tiếp trên cơ sở dữ liệu doanh nghiệp mở ra những bề mặt tấn công chưa từng có: Prompt-to-SQL Injection (phá hoại DDL/DML), Từ chối dịch vụ (DoS qua Cartesian Product/CROSS JOIN), Rò rỉ thông tin định danh cá nhân (PII Exfiltration), Tấn công gián tiếp qua nội dung bảng (Indirect Prompt Injection), Lỗi phó quan bị nhầm lẫn (Confused Deputy), và Nhiễm độc bộ nhớ ngữ cảnh (Persistent Memory Poisoning).

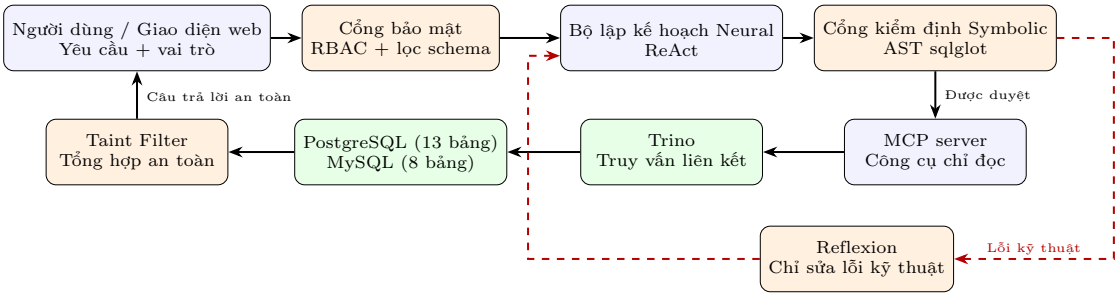
Dự án **Secure Agentic BI Framework** giảm thiểu các rủi ro này bằng cách chuyển từ kiến trúc thuần Neural (phụ thuộc vào khả năng tự kiềm chế của LLM) sang **Kiến trúc Phòng thủ Neuro-Symbolic Đa tầng** kết hợp với **Model Context Protocol (MCP)**. Tại mốc giữa kỳ (Checkpoint D2), nhóm báo cáo đã vận hành hệ thống microservices end-to-end gồm Frontend Vite/React với Dashboard Red-Teaming, Backend FastAPI (Python 3.13), và Trino MCP Server kết nối PostgreSQL (13 bảng) với MySQL (8 bảng), tạo thành cụm cơ sở dữ liệu liên kết 21 bảng. Luồng xử lý gồm sáu bước: RBAC, lọc schema theo quyền tối thiểu, lập kế hoạch Neural ReAct, kiểm định AST bằng `sqlglot`, Reflexion có giới hạn kết hợp kiểm soát timeout/tải, và Taint Filter khi tổng hợp kết quả. Trên bộ kiểm thử 26 kịch bản được mô tả trong báo cáo giữa kỳ, kết quả được báo cáo là **ABR 100%** và **Execution Accuracy 93.8%**; chi phí API trung bình được ghi nhận là **$0.00021 mỗi truy vấn**.

1 Kiến trúc hệ thống và cơ chế bảo mật

1.1 Cơ sở thiết kế

Hệ thống thay thế cách tiếp cận chỉ dựa vào ràng buộc trong prompt bằng kiến trúc Neuro-Symbolic: mô hình ngôn ngữ diễn giải yêu cầu nghiệp vụ và đề xuất truy vấn, còn các bước kiểm tra tất định ở tầng ứng dụng cùng quyền hạn tại cơ sở dữ liệu giới hạn những thao tác có thể thực thi. Cách phân tách này giữ được tính linh hoạt khi lập kế hoạch bằng ngôn ngữ tự nhiên, đồng thời không xem đầu ra của mô hình là quyết định phân quyền. Theo báo cáo giữa kỳ, tầng dữ liệu liên kết PostgreSQL gồm 13 bảng và MySQL gồm 8 bảng, tổng cộng 21 bảng.

Hình 1 tóm tắt luồng xử lý yêu cầu. Trước khi lập kế hoạch, gateway xác định vai trò người gọi dựa trên chính sách lưu trong MySQL và lọc metadata catalog theo phạm vi được cấp quyền. Vì vậy, mô hình chỉ nhận schema đã được thu hẹp thay vì toàn bộ metadata cơ sở dữ liệu. SQL do mô hình đề xuất được phân tích bằng `sqlglot` theo dialect Trino. Chỉ truy vấn vượt qua các kiểm tra chính sách Symbolic mới được chuyển đến Trino thông qua công cụ MCP chỉ đọc đã đăng ký. Kết quả truy vấn đi qua bước tổng hợp có nhận biết dữ liệu không tin cậy trước khi được truyền về giao diện.



Hình 1: Luồng xử lý BI Neuro-Symbolic: kiểm tra chính sách trước khi thực thi và lọc kết quả không tin cậy.

1.2 Phân quyền, kiểm định truy vấn và thực thi

Kiểm soát truy cập dựa trên vai trò (RBAC) được áp dụng trước khi tạo ngữ cảnh schema. Bản ghi chính sách được mô tả trong báo cáo gồm catalog và bảng được phép, bảng bị từ chối, giới hạn số dòng, quyền truy cập PII và quyền xuất tệp. Cơ chế lọc schema loại các bảng ngoài phạm vi khỏi ngữ cảnh của mô hình, qua đó áp dụng nguyên tắc đặc quyền tối thiểu ngay từ prompt. Cách làm này giảm lượng thông tin được cung cấp và độ dài prompt, nhưng không phải chốt kiểm soát cuối cùng. AST guardrail tiếp tục đối chiếu các bảng được tham chiếu với chính sách của người gọi, ngăn mô hình truy vấn bảng bị ẩn chỉ bằng cách nêu tên bảng.

Guardrail phân tích cú pháp SQL được sinh ra thay vì tìm mẫu trên văn bản thô bằng biểu thức chính quy. Báo cáo giữa kỳ mô tả chính sách chỉ chấp nhận một câu lệnh dạng `SELECT`; từ

chối các nút DDL và DML; đồng thời kiểm tra bảng ngoài phạm vi, CTE đệ quy, `CROSS JOIN` và phép JOIN thiếu điều kiện `ON` hoặc `USING`. Những kiểm tra này giảm nguy cơ SQL phá hoại, vượt ranh giới quyền và một số dạng lạm dụng tài nguyên. Tuy vậy, chúng không bảo đảm mọi truy vấn được chấp nhận đều có chi phí hữu hạn; do đó vẫn cần giới hạn thời gian và mức đồng thời. Giao diện MCP mà Agent sử dụng được mô tả là chỉ đọc (`execute_query_read_only`), bên cạnh các công cụ metadata như `list_catalogs` và `describe_table`. Báo cáo cũng nêu quyền truy cập chỉ đọc tại cơ sở dữ liệu như một lớp thực thi độc lập, nhằm tránh cấp quyền ghi cho phiên làm việc của Agent nếu gateway mắc lỗi.

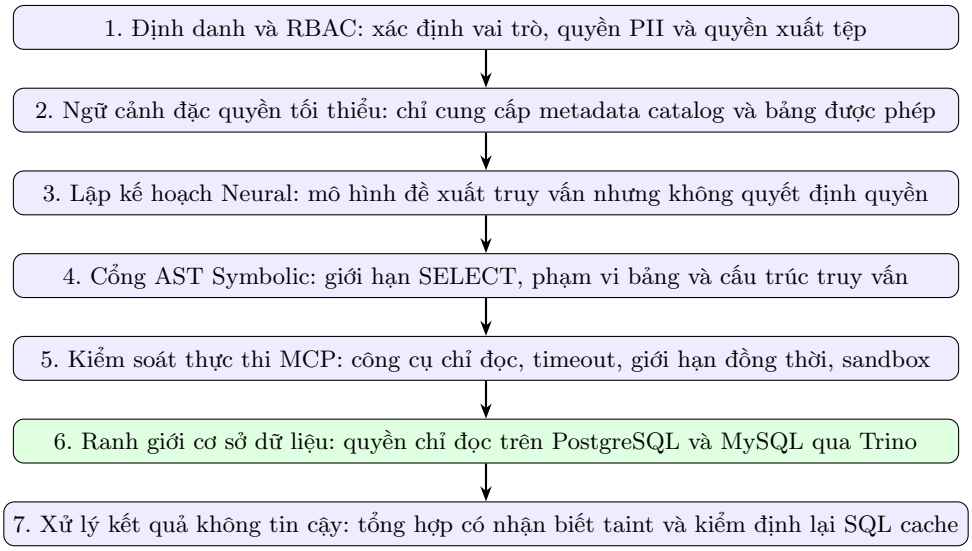
1.3 Vòng lặp Agent, MCP và cơ chế phục hồi

Agent vận hành theo chu trình lập luận–hành động kiểu ReAct: diễn giải câu hỏi, tạo yêu cầu gọi công cụ có cấu trúc, rồi sử dụng phản hồi thực thi để tinh chỉnh truy vấn khi cần [4]. Ranh giới MCP cung cấp giao diện xác định giữa dịch vụ Agent và Trino, thay vì cho mô hình kết nối trực tiếp tới cơ sở dữ liệu. Theo mô tả triển khai, tiến trình FastAPI giao tiếp với MCP server riêng qua stdio bằng JSON-RPC. Công cụ thực thi chỉ đọc có thể trả kết quả trực tiếp hoặc ghi dữ liệu xuất lớn hơn vào đường dẫn trong sandbox, tùy theo quyền của vai trò và kết quả kiểm tra đường dẫn.

Reflexion được giới hạn số lần lặp, không vận hành vô hạn. Lỗi cú pháp hoặc schema do bộ phân tích hay Trino trả về có thể được gửi lại cho mô hình làm phản hồi sửa lỗi; cấu hình D2 được báo cáo giới hạn tối đa ba lần lặp [5]. Mọi truy vấn sau khi sửa đều phải vượt qua lại cùng các bước kiểm tra AST và phân quyền trước khi thực thi. Vi phạm chính sách không phải lỗi được phép thử sửa: SQL bị cấm hoặc tham chiếu bảng trái quyền phải bị từ chối theo nguyên tắc fail-closed, không được gửi lặp cho tới khi tình cờ qua kiểm tra. Phân biệt này duy trì lợi ích của cơ chế sửa lỗi nhưng không biến vòng lặp thử lại thành đường vòng vượt kiểm soát.

Circuit Breaker tại tầng MCP kết hợp timeout cứng, hủy tác vụ khi quá hạn, với semaphore để giới hạn số truy vấn đồng thời. Tài liệu giữa kỳ ghi khoảng timeout không thống nhất (3–10 giây và 5–10 giây) cùng một vết thực thi minh họa 5 giây; do đó, phần này không khẳng định một ngưỡng triển khai cố định và cần xác nhận cấu hình thực tế. Hình 2 phân biệt các kiểm soát ở tầng ứng dụng với ranh giới quyền chỉ đọc tại cơ sở dữ liệu.

Cuối cùng, các dòng dữ liệu trả về được xem là nội dung không tin cậy, không phải chỉ thị. Taint Filter gắn nhãn văn bản trong cơ sở dữ liệu, bao gồm đánh giá, phiếu hỗ trợ và log do người dùng tạo, là dữ liệu thụ động trong bước tổng hợp câu trả lời. Cơ chế này xử lý nguy cơ indirect prompt injection, khi chỉ thị độc hại được lưu trong dữ liệu rồi được truy xuất bởi một truy vấn nghiệp vụ hợp lệ [6]. Tập kết quả lớn có thể được xuất vào sandbox thay vì đưa toàn bộ từng dòng vào ngữ cảnh mô hình. Các biện pháp này giảm mức phơi nhiễm trước nội dung độc hại, nhưng không chứng minh rằng chỉ riêng việc cô lập ở tầng prompt có thể vô hiệu hóa mọi dạng injection.



Hình 2: Phòng thủ nhiều lớp ở tầng ứng dụng và cơ sở dữ liệu. Quyền chỉ đọc tại cơ sở dữ liệu giúp hạn chế tác động nếu một kiểm tra ở tầng ứng dụng thất bại.

2 Phương pháp đánh giá và kết quả thực nghiệm

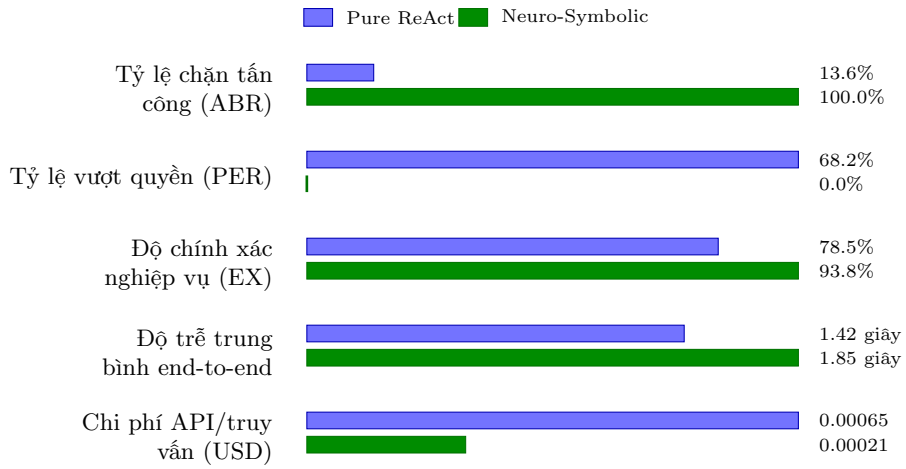
2.1 Tập kiểm thử và chỉ số đánh giá

Đánh giá giữa kỳ mô tả bộ kiểm thử gồm 26 kịch bản: bốn tác vụ hợp lệ (ba truy vấn BI cơ sở và một lần xuất dữ liệu an toàn) cùng 22 kịch bản đối kháng thuộc sáu nhóm tấn công. Các kịch bản kiểm tra SQL injection, lạm dụng tài nguyên, truy cập PII trái phép, chỉ thị độc hại trong văn bản bảng, path traversal và nhiễm độc lịch sử/cache truy vấn. Bộ kiểm thử này khảo sát các cơ chế được báo cáo theo luồng end-to-end; tuy nhiên, quy mô nhỏ và tính chất kịch bản dựng sẵn không đủ để khẳng định bảo mật trong mọi môi trường triển khai.

Báo cáo so sánh cấu hình cơ sở Pure ReAct—trong đó LLM dựa vào prompt và kết nối cơ sở dữ liệu mà không có AST guardrail, Circuit Breaker hay vòng lặp Reflexion—với cấu hình Neuro-Symbolic đầy đủ. Bảng 1 giữ nguyên thứ tự và ý nghĩa các chỉ số theo tài liệu giữa kỳ: ABR và EX càng cao càng tốt, còn PER, độ trễ và chi phí API càng thấp càng tốt. Hình 3 minh họa trực quan kết quả. Trong biểu đồ, từng cặp thanh được chuẩn hóa theo giá trị lớn hơn của chính chỉ số đó; chỉ nên so sánh độ dài thanh trong cùng một chỉ số, không so sánh giữa các chỉ số khác đơn vị.

Bảng 1: So sánh hai cấu hình theo số liệu được báo cáo tại mốc giữa kỳ.

Chỉ số	Pure ReAct	Neuro-Symbolic	Chiều mong muốn
Tỷ lệ chặn tấn công (ABR)	13.6%	100.0%	Cao hơn
Tỷ lệ vượt quyền (PER)	68.2%	0.0%	Thấp hơn
Độ chính xác nghiệp vụ (EX)	78.5%	93.8%	Cao hơn
Độ trễ trung bình end-to-end	1.42 giây	1.85 giây	Thấp hơn
Chi phí API/truy vấn (USD)	0.00065	0.00021	Thấp hơn



Hình 3: Kết quả giữa kỳ của cấu hình Pure ReAct và hệ thống Neuro-Symbolic. Các thanh được chuẩn hóa riêng theo từng chỉ số; nhãn thể hiện giá trị gốc.

2.2 Phân tích kết quả và giới hạn

Trong 22 kịch bản tấn công, ABR được báo cáo tăng từ 3/22 (13.6%) ở cấu hình cơ sở lên 22/22 (100%) ở cấu hình đầy đủ. PER giảm từ 15/22 (68.2%) xuống 0/22. Đây là kết quả quan sát trên bộ kiểm thử đã nêu, không chứng minh rằng mọi biến thể tấn công hoặc môi trường triển khai đều cho kết quả tương tự. Với các truy vấn hợp lệ, EX tăng từ 78.5% lên 93.8%. Báo cáo quy mức cải thiện này chủ yếu cho Reflexion, vốn sửa lỗi cú pháp và schema dựa trên phản hồi thực thi. Do cấu hình đầy đủ đồng thời bổ sung nhiều cơ chế, phép so sánh chưa tách riêng được đóng góp nhân quả của từng thành phần.

Độ trễ trung bình được báo cáo tăng từ 1.42 giây lên 1.85 giây, chênh lệch 0.43 giây giữa hai cấu hình. Không nên diễn giải chênh lệch tổng thể này thành chi phí riêng của bước phân tích AST. Ngược lại, chi phí API được báo cáo giảm từ \$0.00065 xuống \$0.00021 mỗi truy vấn; tài liệu giữa kỳ liên hệ mức giảm này với việc thu hẹp schema đưa vào ngữ cảnh. Đây là số liệu ở giai đoạn giữa kỳ; tài liệu được cung cấp không nêu số lần chạy, phương sai hoặc khoảng tin cậy.

Thí nghiệm ablation dự kiến, so sánh cấu hình cơ sở, chỉ có guardrail và cấu hình đầy đủ qua nhiều seed, sẽ giúp phân tách ảnh hưởng của từng thành phần và đánh giá độ biến thiên.

3 Mô hình đe dọa, phạm vi và hướng phát triển

3.1 Mô hình đe dọa

Hệ thống xét đến cả kẻ tấn công bên ngoài lẫn người dùng đã được cấp quyền nhưng có thể lạm dụng quyền truy cập mà Agent được ủy nhiệm. Tài sản cần bảo vệ gồm các bảng quan hệ nhạy cảm và PII, tính toàn vẹn và tính sẵn sàng của cơ sở dữ liệu, chính sách và cấu hình máy chủ, cùng tính toàn vẹn của lịch sử truy vấn và semantic cache. Các đầu vào được xem là không tin cậy gồm prompt của người dùng, văn bản trong cơ sở dữ liệu do bên thứ ba đóng góp, đường dẫn xuất tệp do Agent đề xuất và SQL truy xuất từ các phiên trước. Mô hình này tương ứng với sáu nhóm tấn công được kiểm tra trong bộ harness giữa kỳ.

- **Prompt-to-SQL injection và thao tác phá hoại:** người dùng tìm cách khiến Agent sinh DDL hoặc DML. Bộ phân tích SQL áp dụng chính sách chỉ chấp nhận `SELECT` trước khi gọi MCP.
- **Từ chối dịch vụ (DoS):** kẻ tấn công đề xuất JOIN tốn kém, truy vấn đệ quy hoặc tạo tải đồng thời quá mức. AST từ chối một số cấu trúc rủi ro cao; timeout và giới hạn đồng thời tiếp tục khống chế quá trình thực thi.
- **Rò rỉ PII và bí mật:** người gọi tìm cách đọc bảng ngoài phạm vi vai trò. Việc chỉ đưa schema tối thiểu vào ngữ cảnh được hỗ trợ bởi bước kiểm tra quyền bảng tại AST và quyền truy cập chỉ đọc ở cơ sở dữ liệu.
- **Indirect prompt injection:** chỉ thị nhúng trong đánh giá, phiếu hỗ trợ hoặc log tìm cách chi phối bước tổng hợp. Văn bản truy xuất được xem là dữ liệu thụ động có gắn nhãn không tin cậy; kết quả lớn có thể được giữ ngoài ngữ cảnh mô hình.
- **Confused deputy và path traversal:** người dùng quyền thấp tìm cách lạm dụng quyền của Agent hoặc đường dẫn xuất tệp. Các biện pháp được báo cáo gồm kiểm tra vai trò, kiểm soát quyền xuất và xác thực đường dẫn trong sandbox.
- **Nhiễm độc bộ nhớ:** truy vấn độc hại được cài vào lịch sử hoặc cache để tái sử dụng về sau. Báo cáo mô tả cơ chế lưu lịch sử/cache dạng quan hệ và yêu cầu SQL truy xuất phải qua AST validation lại.

Kiến trúc giả định vai trò đã xác thực và các bản ghi chính sách được cấu hình đúng; gateway, tiến trình MCP, Trino coordinator và cấu hình quyền cơ sở dữ liệu chưa bị xâm nhập. Kết quả kiểm thử giữa kỳ không đánh giá tình huống các thành phần tin cậy này bị chiếm quyền. Ngoài

ra, gắn nhãn taint là biện pháp ở tầng ứng dụng, không phải bảo đảm hình thức rằng mô hình ngôn ngữ không thể bị ảnh hưởng bởi văn bản độc hại. Vì vậy, mô hình đe dọa cần được hiểu là tập hợp biện pháp ứng phó với các đầu vào và kịch bản đã xác định, không phải khẳng định hệ thống an toàn tuyệt đối.

3.2 Thành phần đã triển khai và phần mở rộng dự kiến

Báo cáo D2 phân biệt pipeline single-agent đã vận hành với các phần mở rộng mới ở mức kế hoạch. Phạm vi được báo cáo là đã triển khai gồm tra cứu vai trò và lọc schema, lập kế hoạch kiểu ReAct, kiểm định AST, Reflexion có giới hạn, kiểm soát timeout và đồng thời, giao diện Trino MCP chỉ đọc, tổng hợp có nhận biết taint, lịch sử/cache truy vấn dạng quan hệ kèm kiểm định lại, và giao diện red-teaming với 26 kịch bản. Báo cáo giữa kỳ mô tả các thành phần này đã hoạt động end-to-end.

Các nội dung sau vẫn là kế hoạch, chưa phải năng lực đã hoàn thành: tách vai trò lập kế hoạch, tối ưu truy vấn và thẩm định bảo mật thành nhiều Agent; kích hoạt cơ sở dữ liệu vector như ChromaDB hoặc Qdrant; đánh giá mô hình cục bộ như Qwen hoặc Llama; và bổ sung công cụ trực quan hóa AST. Đặc biệt, sự hiện diện của bảng quan hệ `semantic_cache` và lịch sử truy vấn không đồng nghĩa với việc đã triển khai dịch vụ bộ nhớ vector. Nếu bổ sung backend bộ nhớ trong tương lai, hệ thống vẫn cần kiểm tra quyền theo từng yêu cầu và kiểm định AST lại khi truy xuất SQL từ cache.

Báo cáo giữa kỳ dự kiến thực hiện ablation với ba cấu hình: baseline Pure LLM, cấu hình chỉ có guardrail và pipeline Neuro-Symbolic đầy đủ; mỗi cấu hình được chạy lặp với nhiều seed. Kế hoạch cũng gồm đo bổ sung độ trễ và số token. Thiết kế này có thể giúp phân biệt ảnh hưởng của AST gate, Reflexion và lọc schema. Trước khi xem kết quả của 26 kịch bản là bằng chứng về khả năng sẵn sàng cho môi trường thực tế, vẫn cần đánh giá trên workload rộng hơn và có thẩm định độc lập.

4 Kế hoạch đến báo cáo cuối kỳ và tự đánh giá tiến độ

4.1 Lộ trình triển khai

Từ Checkpoint D2 (cuối tháng 10/2026) đến báo cáo cuối kỳ ngày 02/12/2026, nhóm dự kiến thực hiện các mốc sau:

Thời gian	Nội dung dự kiến	Phụ trách
Tuần 8		
23–29/10	Mở rộng benchmark từ 26 lên ≥ 50 tác vụ, kết hợp mẫu BIRD/Spider và dữ liệu đối kháng tổng hợp.	Trân, Thành
Tuần 9		
30/10–05/11	Ablation Study ba cấu hình, mỗi cấu hình ba seeds; tổng hợp ABR, PER, EX, số token và latency.	Thành, Trân
Tuần 10		
06–12/11	Thử nghiệm Qwen-2.5-Coder-14B và Llama-3.1-8B qua vLLM/Ollama; tích hợp ChromaDB cho semantic cache kèm kiểm định lại.	Lợi, Thành
Tuần 11		
13–19/11	Phát triển AST Visualizer; walkthrough với một Data Analyst và một chuyên viên SecOps doanh nghiệp.	Trân, Lợi
Tuần 12		
20–26/11	Profiling độ trễ, tối ưu kết nối Trino MCP, hoàn thiện báo cáo D3/D4 và tài liệu kỹ thuật.	Cả nhóm
Tuần 13		
27/11–02/12	Hoàn thiện slide, video demo dự phòng, tổng duyệt 15 phút và báo cáo cuối kỳ ngày 02/12/2026.	Cả nhóm

4.2 Rủi ro và phương án dự phòng

- **Nhiễm độc semantic cache:** áp dụng ngưỡng cosine similarity ≥ 0.92; mọi SQL lấy từ cache phải được kiểm định AST lại theo quyền hiện hành trước khi thực thi.
- **Local LLM sinh sai dialect Trino:** bổ sung ví dụ few-shot về định danh ba phần (`catalog.schema.table`) và dự kiến nâng Reflexion tối đa lên năm lần thử, dựa trên lỗi trả về từ Trino.
- **Vượt quota Gemini khi benchmark:** khi API trả HTTP 429, nguồn báo cáo nêu fallback tự động kết hợp exponential backoff. Thứ tự mô hình:
  `gemini-2.5-flash` → `gemini-3.5-flash` → `gemini-3.1-flash-lite`
  → `gemini-3.5-flash-lite` → `gemma-4-26b-a4b-it`.

4.3 Tự đánh giá tiến độ

Tại D2, nhóm đánh giá dự án **đúng tiến độ**. Vòng điều khiển phòng thủ sáu bước đã chạy end-to-end trên cụm 21 bảng, với 26 kịch bản đạt tỷ lệ chặn tấn công 100% và thực thi nghiệp vụ 93,8%. Kết quả

ghi nhận tại mốc giữa kỳ, trước giai đoạn mở rộng benchmark.

5 Đóng góp thành viên và tuyên bố sử dụng AI

5.1 Đóng góp của các thành viên

Các nhiệm vụ kỹ thuật, tỷ lệ đóng góp và dấu vết Git commit được tổng hợp như sau.

Thành viên	Nhiệm vụ kỹ thuật đã thực hiện	Tỷ lệ	Git commit
Nguyễn Công Thành MSHV 2470744	Kiến trúc Neuro-Symbolic; Backend API Gateway; AST Guardrail, Reflexion, Circuit Breaker; Gemini, Fallback LLM, Taint Filter và tích hợp Trino MCP qua Stdio JSON-RPC.	100%	`140d420`, `aaec853`, `3379de8`, `b2120ee`, `ce7f69f`, `863ff9f`, `7812bac`, `26e849b`, `adf6280`
Phạm Quỳnh Trân MSHV 2470731	Cập nhật Web Console; tích hợp MySQL với Docker Compose và Trino; phân loại lỗi Agent API và phân quyền theo vai trò; chuẩn hóa NDJSON streaming; xây dựng 26 kịch bản red-teaming và tổng hợp Threat Model sáu nhóm.	100%	`0ef0379`, `c1a034e`, `77cc488`
Nguyễn Hữu Lợi MSHV 2470012	Cụm PostgreSQL 16, MySQL 8.4 và Trino bằng Docker Compose; dữ liệu mẫu cho 21 bảng; kịch bản khởi động/tắt hệ thống.	100%	Nhánh `thanh` và `main`

5.2 Tuyên bố sử dụng trí tuệ nhân tạo

- **Thành phần runtime:** Google Gemini 2.5 Flash và các mô hình Flash-lite dự phòng đảm nhiệm Neural SQL Planner (đề xuất kế hoạch truy vấn dạng JSON Tool Call) và Safe Answer Synthesizer (diễn giải kết quả đã qua Taint Filter).
- **Công cụ hỗ trợ lập trình:** Cursor và Windsurf tích hợp Claude 3.5 Sonnet được dùng hỗ trợ mã khung FastAPI, cấu hình Docker Compose/Pydantic, giao diện React/Tailwind, dữ liệu mẫu và kịch bản red-teaming, cùng script chuyển Markdown sang Word.
- **Trách nhiệm học thuật:** Nhóm tự thiết kế và kiểm chứng kiến trúc Neuro-Symbolic, Threat Model sáu nhóm, AST Guardrail, MCP, red-teaming, phân tích và kết luận. Nhóm cùng giảng viên hướng dẫn TS. Lê Xuân Bách thẩm định nội dung; mọi kết luận học thuật đều qua rà soát của con người.

Tài liệu tham khảo

[1] Tao Yu, Rui Zhang, Kai Yang, Michihiro Yasunaga, Dongxu Wang, Zifan Li, James Ma, Irene Li, Qingning Yao, Shanelle Roman, Zilin Zhang, and Dragomir Radev. Spider: A large-scale human-labeled dataset for complex and cross-domain semantic parsing and text-to-SQL task. In *Proceedings of the 2018 Conference on Empirical Methods in Natural Language Processing (EMNLP)*, pages 3911–3921, 2018.

[2] Jinyang Li, Binyuan Hui, Ge Qu, Jiaxi Yang, Binhua Li, Bowen Li, Bailin Wang, Bowen Qin, Rongyu Cao, Ruiying Geng, Nan Huo, Xuanhe Zhou, Chenhao Ma, Guoliang Li, Kevin C. C. Chang, Fei Huang, Reynold Cheng, and Yongbin Li. Can LLM Already Serve as A Database Interface? A BIg Bench for Large-Scale Database Grounded Text-to-SQLs (BIRD). In *Advances in Neural Information Processing Systems (NeurIPS)*, 36, 2023.

[3] Sirui Hong, Yizhang Lin, Bang Liu, et al. Data Interpreter: An LLM Agent For Data Science. In *arXiv preprint arXiv:2402.18679*, 2024.

[4] Shunyu Yao, Jeffrey Zhao, Dian Yu, Nan Du, Izhak Shafran, Karthik Narasimhan, and Yuan Cao. ReAct: Synergizing reasoning and acting in language models. In *International Conference on Learning Representations (ICLR)*, 2023.

[5] Noah Shinn, Federico Cassano, Ashwin Gopinath, Karthik Narasimhan, and Shunyu Yao. Reflexion: Language agents with verbal reinforcement learning. In *Advances in Neural Information Processing Systems (NeurIPS)*, 36, 2023.

[6] Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. In *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security (AISec)*, pages 79–90, 2023.

[7] Edoardo Debenedetti, Jie Zhang, Mislav Balunović, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. AgentDojo: A dynamic environment for benchmarking agent security. In *arXiv preprint arXiv:2406.13352*, 2024.

[8] Edoardo Debenedetti, Ilia Shumailov, Tianqi Fan, Jamie Hayes, Nicholas Carlini, Daniel Fabian, Christoph Kern, Chongyang Shi, Andreas Terzis, and Florian Tramèr. Defeating prompt injections by design. In *IEEE Conference on Secure and Trustworthy Machine Learning (SaTML)*, 2026. arXiv:2503.18813.